

PASTA worksheet

Stages	Sneaker Company
I. Define business and security objectives	Make 2-3 notes of specific business requirements that will be analyzed. • Provide secure user accounts, messaging, and payment processing • Protect customer data privacy and build user trust • Ensure compliance with data protection regulations (PCI-DSS) • Maintain high availability for a smooth shopping experience
II. Define the technical scope	List of technologies used by the application: • API (for communication between app and backend) • SQL (database for storing user and product data) • AES & PKI (for encryption and secure key exchange) • SHA-256 (for hashing sensitive data like passwords) I would evaluate the API and SQL database first because they handle the majority of user data and transactions, making them high-value targets for attackers.
III. Decompose application	(Reference: PASTA data flow diagram) Main process: User searches for sneakers → App queries database → Returns current inventory listings.
IV. Threat analysis	List 2 types of threats in the PASTA worksheet that are risks to the information being handled by the application. Internal Threats: • Malicious insider (employee) accessing customer data • Developer error leading to insecure code External Threats: • Hacker attempting SQL injection to steal user data • Session hijacking to impersonate legitimate users
V. Vulnerability analysis	List 2 vulnerabilities in the PASTA worksheet that could be exploited. Potential Vulnerabilities:

	• Lack of prepared statements in SQL queries (SQL injection risk) • Weak authentication / session management (session hijacking)
VI. Attack modeling	(Reference: PASTA attack tree diagram) Main target: User data • Branch 1: SQL Injection → Lack of prepared statements • Branch 2: Session Hijacking → Weak login credentials or session tokens
VII. Risk analysis and impact	List 4 security controls that you've learned about that can reduce risk. 1. Implement prepared statements and input validation to prevent SQL injection 2. Use strong session management and multi-factor authentication (MFA) 3. Apply encryption (AES) for sensitive data in transit and at rest 4. ☐ Conduct regular code reviews and penetration testing before launch
